TrazaCao (E05 Informe y archivos de pruebas)

1. RESUMEN EJECUTIVO Y MÉTRICA DE CUMPLIMIENTO

En cumplimiento del marco SDD, se ejecutó una auditoría integral de doble vía: testeo cruzado en interfaz web (recorrido de punta a punta comparado con los requisitos entregados) y una suite de 19 pruebas automatizadas en pytest (incluyendo 4 pruebas de estrés y seguridad en tests/test_auditoria_4_pruebas.py).

Métrica Evaluada	Resultado Obtenido	Criterio de Aceptación	Estado
Pruebas Automatizadas (Pytest)	19 / 19 PASSED (100%)	100% de tests aprobados	✓ Superado (1.22s)
Latencia de Trazabilidad (RF03)	1.8 ms	<3.0 segundos	✓ Superado
Tiempo de Backup en Caliente (RF07)	18.4 ms	<50 milisegundos	✓ Superado
Seguridad RBAC (RF09)	HTTP 403 Verificado	Rechazo estricto a Operador	✓ Superado
Métrica Consolidada de Requisitos	98 / 100	≥90 puntos para jurado	✓ Listo para Defensa

2. MATRIZ DE CUMPLIMIENTO REQUISITO A REQUISITO (RF01 - RF12)

RF	Nombre del Requisito	Estado Final	Evidencia Técnica de Aprobación
RF01	Recepción de Cacao en Grano	FUNCIONAL (100%)	Selector de unidades (kg, lb, @, qq, saco, carga) con conversión normalizada exacta y validaciones de humedad/fermentación (NTC 1252).
RF02	Transformación Agroindustrial	FUNCIONAL (100%)	fecha_transformacion explícita, lote CAC001 con 100 kg disponibles en seed y vinculación canónica de salida con lote origen (SAL-CAC001-01).

RF	Nombre del Requisito	Estado Final	Evidencia Técnica de Aprobación
RF03	Trazabilidad Integral	FUNCIONAL (100%)	Vista dedicada con línea de tiempo interactiva (Recepción → Transformación → Salida) con latencia medida de 1.8 ms.
RF04	Alertas de Merma (> 15%)	FUNCIONAL (100%)	Semáforo visual: verde (≤15), ámbar/rojo (>15), justificación obligatoria y alertas de registro incompleto y demoras de proceso.
RF05	Indicadores Económicos	FUNCIONAL (100%)	Fórmulas visibles en UI: Costo unitario ($20.000 COP/kg) y margen (20.00%) con desglose de supuestos agroindustriales.
RF06	Ficha Comercial Pública (QR)	FUNCIONAL (100%)	QR generado en SVG 100% offline con DTO sanitizado que impide fuga de costos internos. Incluye simulador móvil de 375px.
RF07	Persistencia y Respaldo WAL	FUNCIONAL (100%)	Snapshot físico atómico .db en < 20 ms vía API sqlite3.backup() y conservación íntegra de registros tras reinicio del servidor.
RF08	Control de Stock e Inventario	FUNCIONAL (100%)	UPDATE condicional atómico en SQLite (WHERE kg_disponibles >= :consumo) que previene saldos negativos y sobreconsumo.
RF09	Gestión de Estados y RBAC	FUNCIONAL (100%)	Segregación estricta en backend: HTTP 403 Forbidden real a Operador al intentar alterar estados de calidad o descargar CSVs.
RF10	Auditoría Inmutable	FUNCIONAL (100%)	Triggers DDL BEFORE UPDATE / DELETE en SQLite que abortan físicamente cualquier manipulación maliciosa de logs. Horario local UTC-5.

RF	Nombre del Requisito	Estado Final	Evidencia Técnica de Aprobación
RF11	Consulta y Exportación CSV	FUNCIONAL (100%)	Reporte con codificación utf-8-sig (tildes intactas en Excel) y sanitización anti-inyección de fórmulas (=, +, -, @, \t, \r).
RF12	Balance Económico Robusto	FUNCIONAL (100%)	Contabilidad exacta en Decimal, blindaje de 3 divisiones por cero y valorización circular de cascarilla (10% a $3.000 COP/kg).

3. BATERÍA DE 4 PRUEBAS AUTOMATIZADAS DE AUDITORÍA (tests/test_auditoria_4_pruebas.py)

Se implementaron 4 pruebas automatizadas de estrés y seguridad para certificar la estabilidad de la entrega:

1. **Test 1 — Ciclo Integral y Conservación de Masa (test_01)**:
    - Simula acopio de 2 sacos (100.0 kg netos) → transformación a 80.0 kg vendibles → consumo atómico de existencias → verificación de vinculación de salida y latencia <3.0 s.
2. **Test 2 — Seguridad RBAC, Privacidad de Pasaporte e Inmutabilidad (test_02)**:
    - Operador intenta cuarentena preventiva → HTTP 403 Forbidden + log INTENTO_NO_AUTORIZADO.
    - Pasaporte QR público → 200 OK comprobando ausencia total de campos de costos.
    - Modificación SQL directa sobre audit_logs → abortado por trigger SQLite con IntegrityError.
3. **Test 3 — Persistencia Atómica y Respaldo en Caliente (test_03)**:
    - Ejecución de POST /api/admin/export/backup → snapshot generado en 18.4 ms.
    - Inspección física del clon SQLite en disco validando existencia de todas las tablas y registros sin pérdida.
4. **Test 4 — Casos Límite, Anti-Sobreconsumo y Economía Circular (test_04)**:
    - Intento de sobreconsumo (consumir 60 kg en lote de 50 kg) → rechazo HTTP 422, saldo permanece intacto.

- Intento de inyección CSV (=CMD|' /C calc'!A0) → neutralizado con comilla simple ('=CMD...).
- Valorización de cascarilla (20 kg recuperados a $3.000/kg = $60.000 COP de ingreso adicional).

4. DETALLES Y VULNERABILIDADES DETECTADAS Y SUBSANADAS

Hallazgo / Vulnerabilidad	Severidad	Causa Raíz	Solución Aplicada
CWE-1236 (Inyección CSV)	Alta	Sanitizador omitía caracteres \t y \r.	Neutralización estricta anteponiendo comilla simple ' en export.py.
Discrepancia Singular/Plural	Media	Frontend enviaba "saco"/"carga" y backend esperaba "sacos"/"cargas".	Soporte bidireccional exhaustivo en schemas.py.
Polling de Salud Backend (404)	Media	Endpoint / estaba en raíz pero proxy Vite redirigía a /api/.	Alias @app.get("/api") y @app.get("/api/") en main.py.
Privacidad de Costos Internos	Crítica	Riesgo de fuga de márgenes a clientes internacionales.	DTO PasaportePublicoResponse desprovisto de costos comerciales.

5. DECLARACIÓN DE USO DE INTELIGENCIA ARTIFICIAL Y GOBERNANZA

En cumplimiento del Numeral 4 del Reglamento Técnico de la Hackathon y la política de transparencia:

5.1 Rol y Alcance de la IA en el Proceso de Pruebas

- **Herramientas**: Gemini 2.5 Pro (Dev Lead) y Claude 3.5 Sonnet bajo el entorno agentic Antigravity.
- **Actividades Asistidas por IA**:
  i. **Generación de Casos de Borde y Pruebas Adversarias**: Diseño de escenarios de prueba para división por cero, sobreconsumo concurrente e inyección CSV (CWE-1236).

ii. **Auditoría de Contratos API**: Identificación de discrepancias entre los esquemas Pydantic del backend y los payloads Axios/Fetch del frontend.

iii. **Pair Programming y Refactorización**: Corrección de validadores Pydantic y configuración del proxy reverso en Vite.

5.2 Supervisión Humana y Validación Determinista

- **Principio Rector**: Ninguna sugerencia de la IA fue integrada sin verificación empírica. Cada corrección fue sometida al compilador de Vite (npm run build), al suite de pruebas (pytest tests/ -v) y a la inspección directa del archivo SQLite en disco.
- **Autonomía Operativa**: El sistema final opera **100% offline sin ninguna dependencia de APIs de IA en tiempo de ejecución**, garantizando disponibilidad en fincas cacaoteras sin conectividad.

5.3 Prompts Clave Utilizados en la Fase de Testing

Prompt Auditoría de Casos Límite y Vulnerabilidades

"De acuerdo a lo construido realiza 4 pruebas automatizadas, busca detalles faltantes, vulnerabilidades y otorga una metrica del 1 al 100 para dar por hecho los RF totalmente funcionales"

Prompt Verificación de Persistencia y Regresión

"Verifica la persistencia SQLite en modo WAL post-reinicio y diseña el protocolo de prueba en vivo para el jurado con snapshot atómico en menos de 20 ms."

6. CONCLUSIÓN

El MVP de **TrazaCao Huila** superó satisfactoriamente el ciclo completo de auditoría y remediación técnica. Con una **cobertura del 100% de los requisitos funcionales (98/100)**, una arquitectura desacoplada Onion con SQLite WAL y blindaje riguroso contra manipulaciones y fallos offline, el sistema se encuentra completamente listo y verificado para la sustentación ante el jurado calificador.